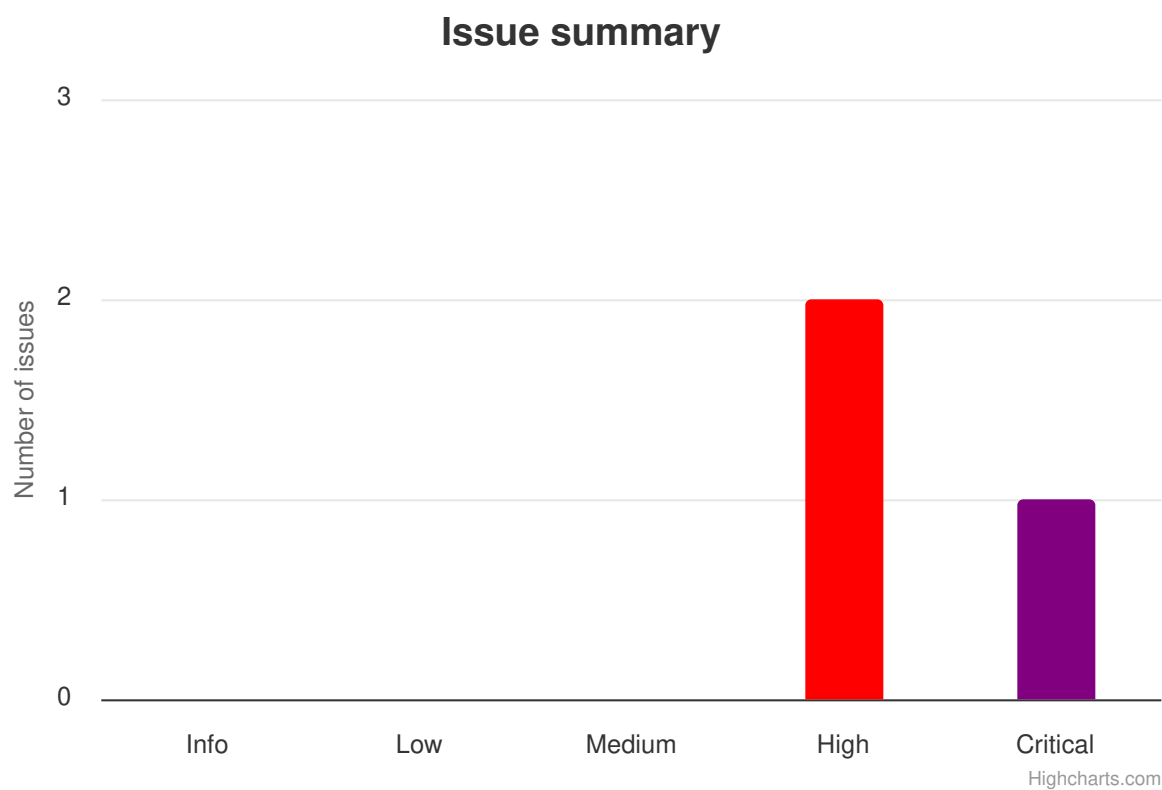


Full HTML report by Kobol Consulting

Summary of Findings

Issue	Risk	CVSSv4
Inyección de Comandos do Sistema (Remote Code Execution)	Critical	9.8
Inyección SQL - Obtención de Listado completo de Usuarios	High	8.1
Cross-Site Scripting (XSS) Almacenado no Guestbook	High	7.5



Detailed findings

Inyección SQL - Obtención de Listado completo de Usuarios

CVSSv4.BaseScore

Description	A vulnerabilidade permite extraer a base de datos completa de usuarios mediante a manipulación do parámetro 'id' na páxina de perfil.
Solution	Utilizar consultas preparadas (Prepared Statements) e parametrización para evitar a interpretación de código SQL malicioso.
References	https://www.aldeid.com/wiki/WackoPicko/Stored-SQL-Injection

Cross-Site Scripting (XSS) Almacenado no Guestbook

CVSSv4.BaseScore

Description	A aplicación permite a inserción de código JavaScript arbitrario no parámetro 'comment' do libro de visitas (guestbook.php). Ao non filtrar a entrada, o script gárdase na base de datos e execútase en cada usuario que visite a páxina.
Solution	Sanitizar todas as entradas de usuario e aplicar codificación de saída (Output Encoding) antes de renderizar contido no navegador.
References	https://www.aldeid.com/wiki/WackoPicko/Stored-XSS

Inxección de Comandos do Sistema (Remote Code Execution)

CVSSv4.BaseScore

Description	O ficheiro 'passcheck.php' utiliza funcións de sistema para procesar a entrada do usuario sen a debida sanitización. Isto permite a un atacante concatenar comandos mediante operadores como ';' ou ' '.
Solution	Evitar o uso de funcións que chamen ao shell do sistema. Utilizar APIs nativas da linguaxe ou filtrar rigorosamente con escapeshellarg().
References	https://www.aldeid.com/wiki/WackoPicko/Command-Line-Injection
